

M5 - Progetto fine modulo

Security Operations

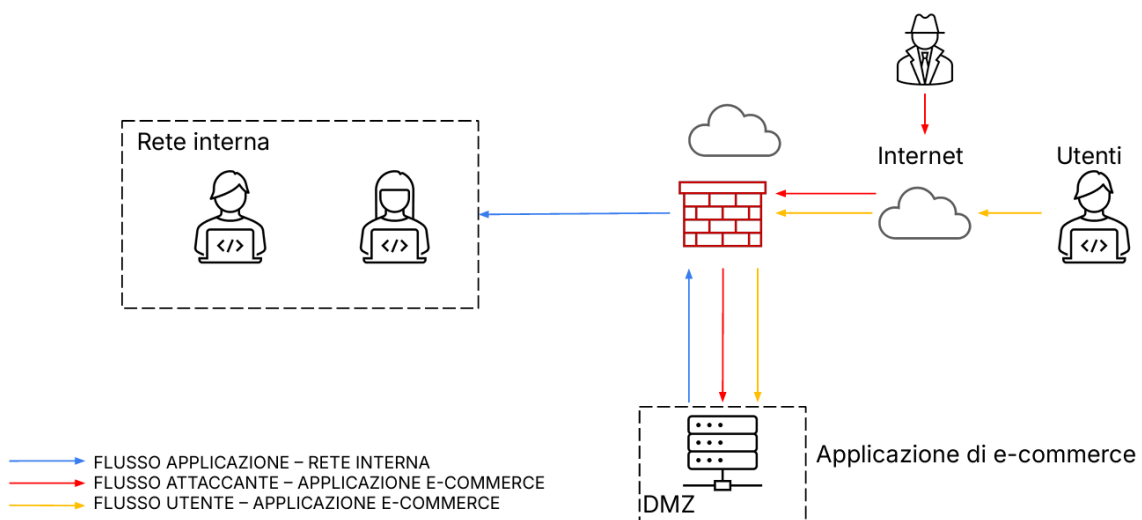
Indice

1. Executive Summary	pag. 2
2. Architettura di Rete	pag. 2
3. Quesito 1	pag. 3
4. Quesito 2	pag. 5
5. Quesito 3	pag. 6
6. Quesito 4	pag. 8

1. Executive Summary

Il presente documento valuta la sicurezza del nostro portale e-commerce rispetto a minacce critiche come il furto di dati (SQL/CSS), blocchi del servizio (**DDoS**) e infezione da Malware. L'obiettivo è evolvere l'attuale infrastruttura verso un modello di **difesa stratificata**: un sistema capace di neutralizzare gli attacchi al sito web e, soprattutto, di garantire che eventuali infezioni da **malware** restino isolate, impedendo ogni accesso non autorizzato ai computer e ai dati della nostra **Rete Interna**.

2. Architettura di Rete



Composizione:

- **Internet:** Rappresenta la rete pubblica esterna da cui provengono sia gli utenti legittimi che i potenziali attaccanti.
- **Firewall (l'icona del muro di mattoni):** È il cuore della sicurezza. Filtra il traffico in entrata e in uscita, decidendo cosa può passare tra le diverse zone (Internet, DMZ e Rete Interna).
- **DMZ (DeMilitarized Zone):** Una zona isolata che contiene l'**Applicazione di e-commerce**. È separata dalla rete interna affinché, in caso di compromissione del server web, l'attaccante non abbia accesso diretto ai computer o ai database privati dell'azienda.

- **Rete Interna (Internal Network):** La zona più protetta dove risiedono gli operatori/sviluppatori aziendali. Qui si trovano i dati sensibili e le postazioni di lavoro.

Analisi dei Flussi di Traffico:

- **Giallo - Flusso Utente:** Rappresenta i clienti che accedono all'e-commerce. Il traffico passa da Internet, attraversa il firewall e arriva ai server nella DMZ.
- **Rosso - Flusso Attaccante:** Simula un tentativo di hacking. L'attaccante cerca di colpire l'applicazione nella DMZ. Il firewall ha il compito di bloccare i tentativi malevoli, ma l'applicazione rimane il primo bersaglio.
- **Blu - Flusso Applicazione:** Indica la comunicazione tra l'applicazione (DMZ) e la Rete Interna. Solitamente serve per aggiornamenti, gestione del database interno o ordini.

3. Quesito 1

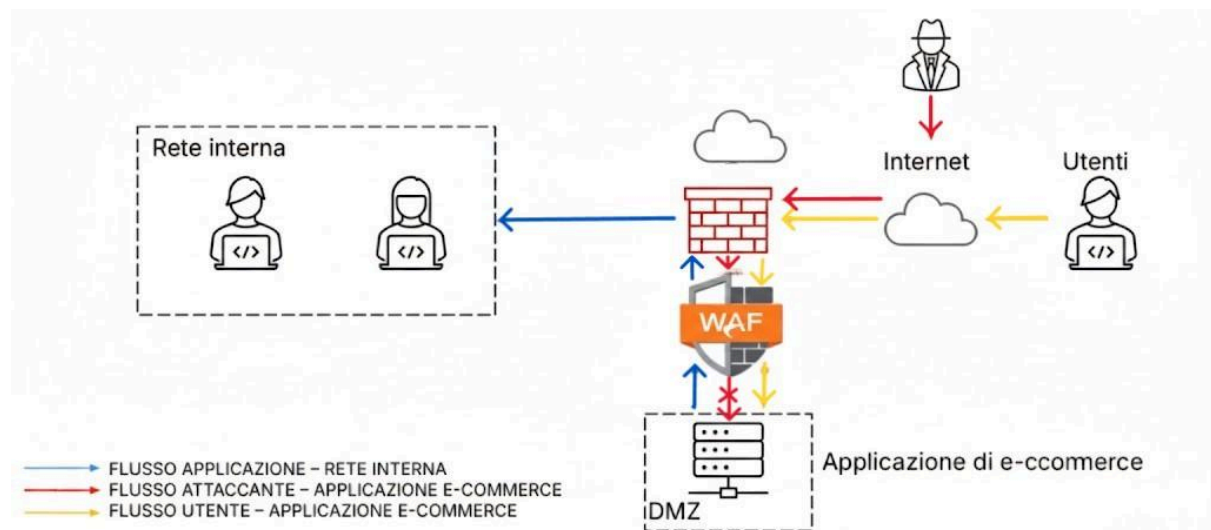
Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo **SQLi** oppure **XSS** da parte di un utente malintenzionato?

Modificate la figura in modo da evidenziare le implementazioni.

Minacce:

- **SQLi** : Una **SQL Injection (SQLi)** è una vulnerabilità di sicurezza che permette a un attaccante di interferire con le query che un'applicazione rivolge al proprio database. L'attaccante inserisce comandi SQL arbitrari che l'interprete esegue erroneamente come codice legittimo. Ciò consente di bypassare l'autenticazione, visualizzare dati riservati, modificarli o eliminarli, compromettendo l'intera integrità del sistema.
- **XSS** : **Cross-Site Scripting (XSS)** è una vulnerabilità che consente a un utente malintenzionato di inserire ed eseguire script malevoli nelle pagine web visualizzate da altri utenti. L'attaccante può rubare cookie di sessione, reindirizzare le vittime a siti di phishing o manipolare il contenuto della pagina.

Azioni preventive:



Utilizzo del **WAF (Web Application Firewall)**

In questa architettura, il **WAF** agisce come uno scudo intelligente posizionato davanti all'e-commerce. Mentre il firewall tradizionale controlla gli accessi, il WAF, lavorando al layer 7 del modello OSI (Application Layer), analizza il **contenuto** del traffico HTTP. Per quanto riguarda la **SQL Injection**, il WAF blocca i comandi database malevoli e contro l'**XSS**, lo scudo filtra gli script pericolosi iniettati nei campi di input, prima che raggiungano il server, come indicato dalla **X** nel diagramma.

In sintesi, il **WAF** distingue i dati legittimi dai tentativi di furto o manipolazione del codice. Senza di esso, l'applicazione nella **DMZ** sarebbe vulnerabile ad attacchi mirati che superano i normali controlli di rete. È l'elemento che garantisce l'integrità dei dati tra la **Rete Interna** e il web.

4. Quesito 2

L'applicazione Web subisce un attacco di tipo **DDoS** dall'esterno che rende l'applicazione non raggiungibile per 10 minuti.

Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce.

Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica

Minaccia:

- **DDoS (*Distributed Denial of Service*)**: è un attacco che mira a rendere inagibile un sito web o un servizio online sovraccaricandolo di traffico. A differenza di **SQLi** o **XSS**, non cerca di rubare dati, ma di esaurire le risorse del server (CPU, memoria o banda). L'attaccante utilizza una **botnet**, ovvero migliaia di dispositivi infetti (PC, telecamere, IoT) sparsi nel mondo e controllati da remoto. Questi "dispositivi zombie" inviano simultaneamente una quantità enorme di richieste legittime in apparenza, ma letali per il volume. Il risultato è che il server, non riuscendo a gestire la mole di dati, rallenta drasticamente o smette di funzionare. Gli utenti reali (il flusso giallo in foto) restano così bloccati fuori dal servizio.

Calcolo impatto sul business:

- **Durata disservizio**: 10 minuti
- **Spesa media per minuto**: 1500 euro

Calcolo : $10\text{min} \times 1500 \text{ euro/min} = 15000 \text{ euro}$

Questo rappresenta il calcolo dell'impatto diretto sul business sulla base dei mancati acquisti degli utenti, ma, in uno scenario reale, c'è bisogno di preventivare ulteriori perdite a livello economico, dovute ad esempio a:

- **Costi operativi**: Il tempo del team IT impiegato per ripristinare i sistemi.
- **Danno reputazionale**: Clienti che abbandonano il carrello e passano alla concorrenza.

Azioni preventive:

- **Rate Limiting:** È la difesa più efficace contro i bot. Consiste nell'impostare una soglia massima di richieste che un singolo visitatore può fare in un determinato tempo. Se un IP supera la soglia (es. più di 50 richieste al minuto), il **WAF** lo "taglia fuori" temporaneamente, salvando le risorse del server per gli altri clienti.
- **Filtro IP Reputation:** per bloccare automaticamente indirizzi IP noti per attività malevole o provenienti da botnet.
- **CAPTCHA:** Quando il traffico verso l'e-commerce aumenta improvvisamente, il **WAF** non può bloccare tutti. Invece di chiudere la porta, lancia una "sfida" (es: "Clicca qui se sei un umano" o "Seleziona i semafori"). In questo modo, l'utente reale, rispondendo, riesce ad entrare nella piattaforma di e-commerce, mentre i bot, non essendo in grado di "leggere" immagini o risolvere enigmi logici, falliscono e rimangono bloccati.

5. Quesito 3

L'applicazione Web viene infettata da un **malware**. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

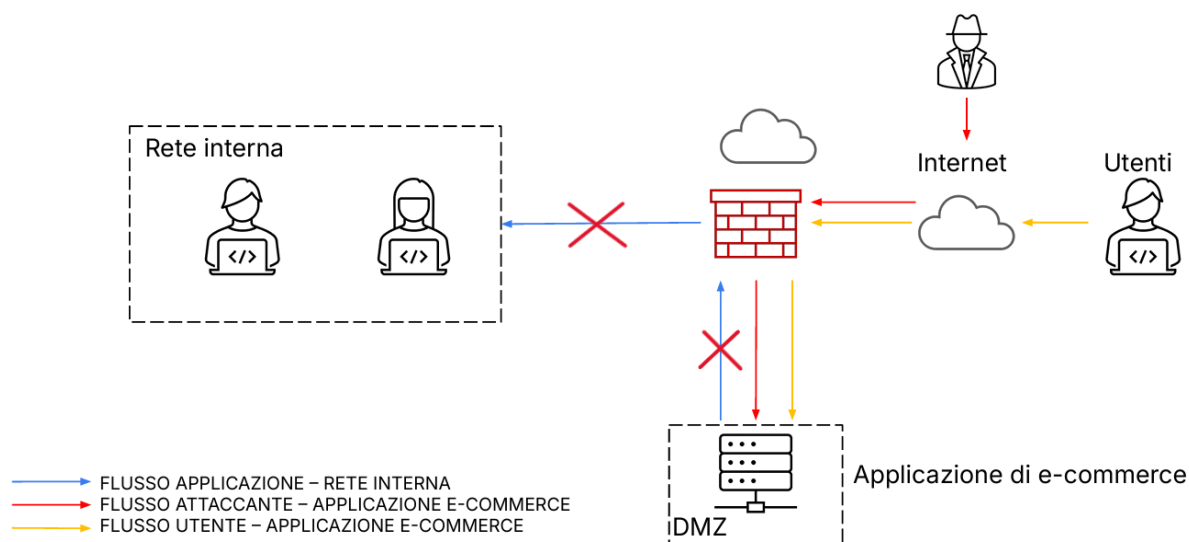
Minaccia:

- **Malware:** qualsiasi programma o codice informatico progettato con l'intento doloso di infiltrarsi, danneggiare o ottenere accessi non autorizzati a un sistema. Questa categoria comprende minacce eterogenee come **virus**, **trojan**, **spyware** e **ransomware**, ognuna con strategie di attacco specifiche. Alcuni malware mirano a sottrarre dati sensibili come credenziali bancarie, mentre altri criptano i file per richiedere un riscatto in denaro.

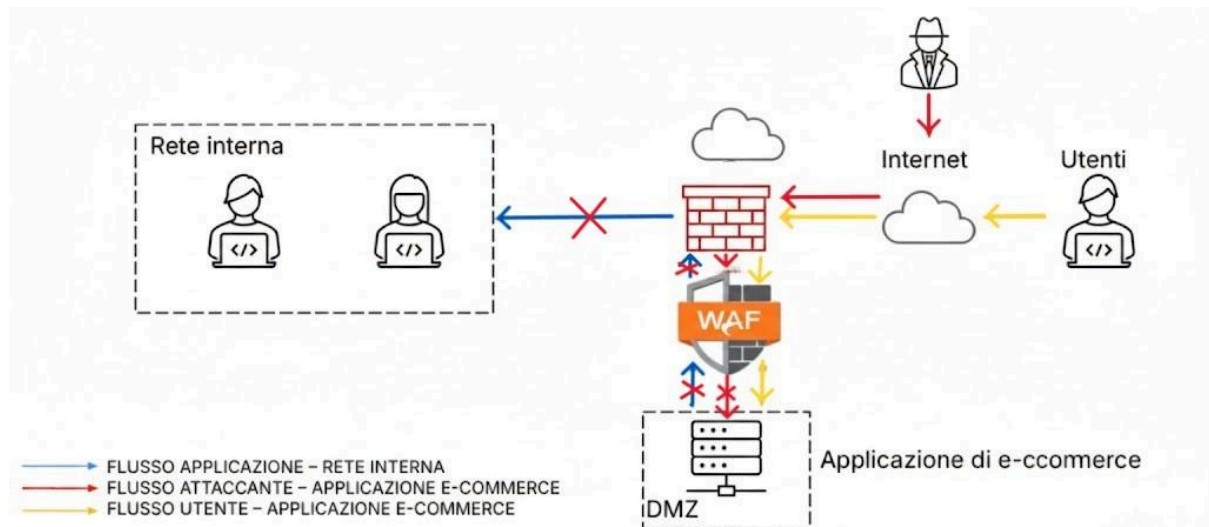
Incident Response: Contenimento Malware DMZ

Al fine di neutralizzare la minaccia e prevenire il **movimento laterale** del malware verso la rete interna, si propone una strategia di **micro-segmentazione** drastica. L'obiettivo primario è la protezione della **Rete Interna**, rendendo la DMZ isolata rispetto al resto dell'infrastruttura. La soluzione identificata come più efficace consiste nell'**isolamento totale della DMZ** e, per attuare questa misura, è necessario intervenire sulla configurazione del **Firewall** attraverso:

- Eliminazione o disattivazione immediata di tutte le regole che permettono il traffico originato dalla **DMZ** verso la **Rete Interna**.
- Implementazione di una regola di "chiusura totale" tra i due segmenti, garantendo che nessun pacchetto dati possa scavalcare il perimetro di sicurezza, anche in caso di persistenza dell'attaccante sul server e-commerce.
- Mantenimento della Disponibilità Esterna: Come da requisiti, la configurazione manterrà invariati i flussi in ingresso da Internet (Utenti e Attaccante), limitando l'impatto del malware al solo perimetro già compromesso. Così facendo, isolando la **DMZ**, sarà anche possibile monitorare il comportamento del malware in un ambiente controllato.



6. Quesito 4 - Soluzione completa



L'immagine rappresenta l'architettura di sicurezza di una rete aziendale progettata per proteggere un'applicazione di e-commerce dagli attacchi provenienti dal web.

La configurazione risulta sicura poiché:

- Il **WAF** protegge il software dell'e-commerce dagli hacker.
- Anche se un hacker riuscisse a prendere il controllo del server e-commerce (nella DMZ), non potrebbe accedere ai computer della **Rete interna** perché, all'interno del **Firewall**, sono state applicate regole che bloccano il traffico proveniente dalla **DMZ**.

Roma, 26/02/2026
Riccardo Ricci